

UNIT -2

Scanning Methodology

- Scanning methodology is a **structured approach** used by ethical hackers to systematically discover live systems, open ports, services, and vulnerabilities within a target network.
- **EC-Council Scanning Phases Overview**
 1. Identify live systems
 2. Identify open ports
 3. Evade IDS/IPS
 4. Perform banner grabbing
 5. Scan for vulnerabilities
 6. Draw network diagrams
 7. Use proxies for anonymity

Identifying Live Systems & Open Ports

- **Phase 1: Check for Live Systems**

- The first step is to determine which systems in the target subnet are active.
- Techniques include ICMP ping sweeps, ARP scans, and TCP-based host discovery.
- This reduces scanning effort by focusing only on machines that are online.

- **Check for Open Ports**

- After identifying live hosts, the next step is to determine which ports are open.
- Each open port represents a running service and potential entry point.
- For example:
 - Port 80 → Web server
 - Port 22 → SSH
 - Port 3306 → MySQL database
- Misconfigured or unnecessary open ports are common causes of breaches.

Bypassing Detection & Service Identification

Phase 3: Scan Beyond IDS

- Modern organizations deploy IDS/IPS systems to detect scanning behavior.
- Ethical hackers may use stealth techniques such as SYN scans, packet fragmentation, slow scanning, and decoy IPs.
- The goal is to simulate real attacker behavior and test detection capability.

Phase 4: Banner Grabbing & OS Fingerprinting

- Banner grabbing helps identify service versions and operating systems.
- It reveals software details such as:
 - Apache 2.4.49
 - Microsoft IIS 10
 - Ubuntu Linux 20.04
- Knowing the version allows mapping against known CVEs.
- Many successful attacks exploit outdated software versions.

Vulnerability Analysis & Network Mapping

- **Phase 5: Vulnerability Scanning**
- Once services are identified, vulnerability scanners check for unpatched weaknesses.
- Tools compare service versions against vulnerability databases.
- Example: An outdated Apache server vulnerable to remote code execution.
- Ethical hackers document severity, impact, and remediation.

- **Phase 6: Drawing Network Diagrams**

- Network diagrams show logical and physical structure.
- Helps understand trust relationships between:
 - DMZ
 - Internal network
 - Database servers
 - Firewalls
- Important for identifying lateral movement paths.
- Example: Compromised web server connecting to internal database

Proxies

- **Phase 7: Preparing Proxies**
- Proxies help obscure the source of scanning traffic.
- Used to simulate real-world attacker anonymity.
- Includes VPNs, proxy chains, and Tor routing.
- Ensures logs do not directly reveal tester's IP

Introduction to Port Scanning

- Port scanning is a technique used to identify **open ports and services running on a target system**.
- Each open port represents a potential entry point into a system.
- Ethical hackers use port scanning to understand the **attack surface** of a network.

Port Scan Types

- TCP Connect Scan
- SYN Scan
- FIN Scan
- NULL Scan
- XMAS Scan
- ACK Scan
- IDLE Scan

Full Connect Scan (TCP Connect Scan)

◆ What It Does

- Completes full three-way handshake.
 - Immediately tears down connection using RST.
 - Most reliable but easiest to detect.
-

◆ Responses

- Open Port → SYN/ACK
 - Closed Port → RST
-

◆ Real-World Use

Used when:

- Stealth is not required
- Accuracy is more important



Stealth Scan (SYN Scan / Half-Open)

◆ How It Works

- Sends SYN packet.
 - If SYN/ACK received → sends RST instead of ACK.
 - Connection never fully established.
-

◆ Why It's Stealthy

- Does not complete handshake.
 - Harder to log at application level.
 - Bypasses some basic logging systems.
-

◆ Responses

- Open → SYN/ACK
- Closed → RST

Inverse TCP Flag Scan (FIN / NULL / URG / PSH)

◆ How It Works

- Sends unusual TCP flags instead of SYN.
 - May send:
 - FIN
 - NULL (no flags)
 - URG
 - PSH
-

◆ Responses

- Open Port → No response
- Closed Port → RST

Opposite of SYN scan behavior.

◆ Purpose

- Bypass simple firewalls.
- Avoid detection systems looking for SYN packet.

XMAS Scan

◆ Why Called XMAS?

- All TCP flags turned ON.
 - Packet is "lit up like a Christmas tree."
-

◆ Behavior

Same response pattern as FIN scan:

- Open → No response
- Closed → RST

ACK Flag Probe

◆ Purpose

ACK scan is NOT used to find open ports directly.

It is used to:

- Detect firewall presence
- Identify filtered vs unfiltered ports

If:

- No response → Stateful firewall blocking
- RST received → No firewall

Used for firewall rule mapping.

IDLE Scan (Zombie Scan)

◆ Most Stealthy Technique

- Uses third-party “zombie” system.
 - Attacker does not directly contact target.
 - Uses IPID sequence numbers.
-

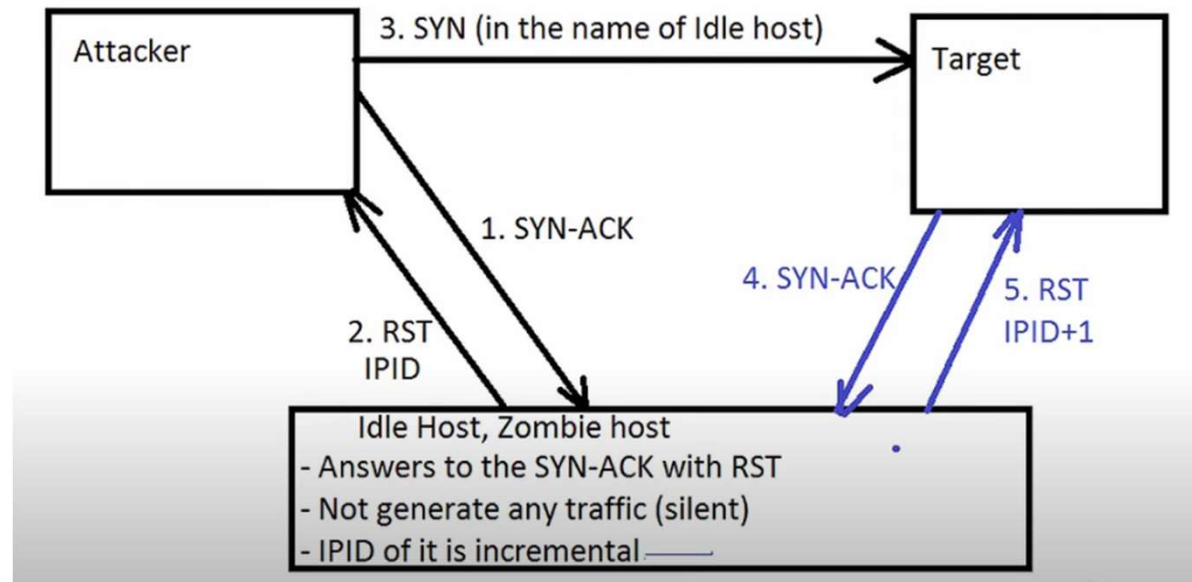
◆ How It Works

1. Check zombie IPID.
 2. Spoof zombie IP to target.
 3. Monitor IPID changes.
 4. Determine open/closed status.
-

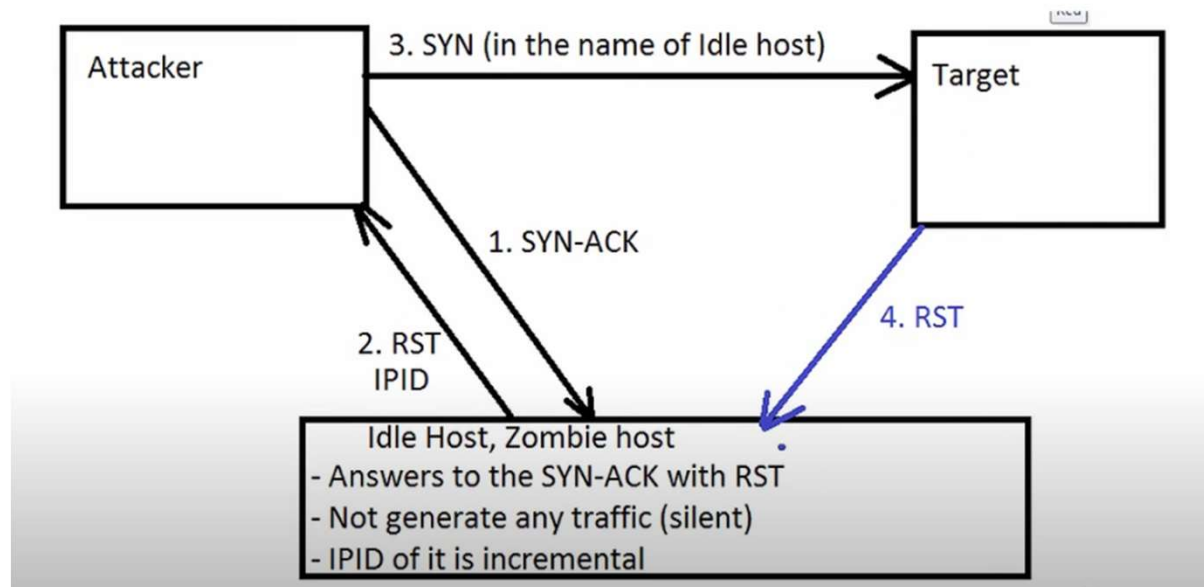
◆ Why Powerful

- Target logs show zombie IP.
- Attacker remains hidden.
- Very difficult to trace.

Port Open



Port Close



Comparing Port Scan Types

Scan Type	Stealth	Detectability	Purpose
Full Connect	Low	Easy	Reliable scanning
SYN Scan	Medium	Moderate	Common stealth scan
FIN/NULL	High	Harder	Firewall bypass
XMAS	High	Harder	Stealth testing
ACK	Medium	Moderate	Firewall detection
IDLE	Very High	Very Hard	Anonymous scanning

Introduction to Evasion

- **What is Evasion?**

- Evasion refers to techniques used by attackers to avoid detection while performing scanning or attacks.
- The goal is to bypass firewalls, IDS (Intrusion Detection Systems), and monitoring tools.
- Ethical hackers use evasion during testing to evaluate how well security systems detect suspicious behavior.

- **Why Evasion Matters**

- Modern networks continuously monitor traffic.
- Simple scans trigger alerts.
- Real attackers always try to remain unnoticed.

Why Security Systems Detect Scanning

- **Firewalls & IDS Behavior**

- Firewalls block traffic based on predefined rules.
- IDS monitors patterns such as rapid SYN packets or abnormal TCP flags.
- SIEM(Security Information and Event Management) systems correlate logs and raise alerts.

- **Problem for Attackers**

- Repeated connection attempts = suspicious behavior.
- Unusual traffic spikes = alert triggered.
- Direct scans often get blocked.

Packet Fragmentation

- **What is Packet Fragmentation?**

- Breaking one large packet into smaller pieces.
- TCP header information gets split across fragments.

- **Why It Works**

- Some IDS systems inspect full packets.
- If headers are fragmented, detection engines may fail to reconstruct properly.
- The scan appears as random small traffic.

IP Spoofing

- **What is IP Spoofing?**
 - Attacker modifies source IP address in packet.
 - Target believes traffic came from another system.
- **Why Use It?**
 - Hide real identity.
 - Bypass IP-based filtering.
 - Launch reflection or DoS attacks.
- **Limitation**
 - Responses go to fake IP.
Attacker may not receive reply.

Source Routing

- **What is Source Routing?**
 - Attacker specifies the path packet should follow.
 - Overrides normal routing decisions.
- **Why It Was Used**
 - Bypass monitoring devices.
 - Manipulate return path.
 - Control routing flow.
 - Mostly blocked in modern networks.

IP Address Decoy

- **What is Decoy Scanning?**
 - Real IP hidden among multiple fake IPs.
 - Makes it look like many systems are scanning.
- **Why It Works**
 - Confuses incident response teams.
 - Makes attribution difficult.
 - Delays investigation.
 - Hide the attacker inside a crowd.

Proxy Servers

- **What is a Proxy?**

- Intermediary between attacker and target.
- Traffic is relayed through proxy.

- **Why Use Proxy?**

- Hide real IP address.
- Change geographic origin.
- Avoid direct traceability.

- **Monitoring Impact**

- Logs show proxy IP, not attacker.

Proxy Chains & Tor

- **Proxy Chains**

- Multiple proxies layered together.
- Each hop adds anonymity.
- Traffic path:
Attacker → Proxy1 → Proxy2 → Target

- **Tor (Onion Routing)**

- Traffic encrypted in layers.
- Routed through random global nodes.
- Destination sees only exit node.

Anonymizers

- **Web Anonymizers**
- Web-based proxy services.
- Hide source IP for HTTP traffic.
- Examples include Psiphon, Ultrasurf, Tails OS.

Evasion Summary

Technique	What It Does	Goal
Packet Fragmentation	Break attack into small pieces	Bypass IDS
IP Spoofing	Fake source IP	Hide identity / DDoS
IP Decoy	Use multiple fake IPs	Confuse defenders
Proxy/Tor	Route through many nodes	Hide origin
Anonymizers	Leave no trace	Avoid forensic tracking

Vulnerability Scanning

- Vulnerability scanning is the process of using automated tools to identify known security weaknesses, missing patches, and misconfigurations in systems, networks, and applications.
- It goes beyond port scanning by analyzing service versions and comparing them with vulnerability databases like CVE and NVD.
- It is an active technique and may trigger IDS/IPS alerts because it directly interacts with target systems.
- Many real-world cyberattacks exploit known unpatched vulnerabilities, such as the WannaCry attack that abused the EternalBlue flaw in Windows systems.
- Ethical hackers use vulnerability scanning to proactively identify weaknesses before attackers can exploit them.

Vulnerability Scanning Tools & Real-World Use

- Nessus is an industry-standard vulnerability scanner that performs asset discovery, configuration auditing, malware detection, and compliance checks.
- Credentialed scans provide deeper internal analysis, while non-credentialed scans simulate an external attacker's view.
- Other popular tools include OpenVAS (open-source), Qualys (cloud-based web scanning), and GFI LanGuard (includes patch management).
- Organizations use vulnerability scanning to meet compliance standards such as PCI-DSS, HIPAA, and ISO 27001.
- Vulnerability scanning identifies weaknesses but does not exploit them; it supports risk prioritization and remediation planning.

Enumeration

- **Definition**
- Enumeration is the process of **actively extracting detailed information** from a target system.
- Occurs after scanning in the ethical hacking methodology.
- More intrusive than simple port scanning.
- **Objectives**
- Identify:
 - Operating system version
 - Running services & versions
 - User accounts
 - Network shares
 - Domain structure
 - Device configurations

Banner Grabbing Fundamentals

- **What is Banner Grabbing?**
 - Sending a request to an open port.
 - Capturing the returned banner message.
- **What a Banner May Reveal**
 - Application name
 - Software version
 - OS details
 - Service pack level
 - Internal naming conventions
- **Why It's Powerful**
 - Version disclosure enables:
 - CVE matching
 - Exploit research
 - Patch assessment

Active vs Passive Banner Grabbing

- **Active Banner Grabbing**

- Sends specially crafted packets.
- Direct interaction with target.
- Examples:
 - Telnet connection
 - Netcat connection
 - Nmap service detection

- **Passive Banner Grabbing**

- No direct probing.
- Observes:
 - Error messages
 - HTTP headers
 - Network sniffing
 - File extensions (.php, .aspx)

Comparison

Feature	Active Banner Grabbing	Passive Banner Grabbing
Interaction	Directly interacts	No direct interaction
Detection Risk	Higher	Lower
Speed	Fast	Slower
Stealth	Less stealthy	Very stealthy
Tools Used	Telnet, Netcat, Nmap	Browser, Wireshark
IDS Alert?	Often yes	Rarely

Banner Grabbing

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# nc 192.168.179.146 80  
HEAD / HTTP/1.0  
HTTP/1.1 400 Bad Request  
Date: Tue, 01 Aug 2017 16:26:23 GMT  
Server: Apache/2.4.25 (Debian)  
Content-Length: 301  
Connection: close  
Content-Type: text/html; charset=iso-8859-1  
  
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">  
<html><head>  
<title>400 Bad Request</title>  
</head><body>  
<h1>Bad Request</h1>  
<p>Your browser sent a request that this server could not understand.<br />  
</p>  
<hr>  
<address>Apache/2.4.25 (Debian) Server at 127.0.1.1 Port 80</address>  
</body></html>  
root@kali:~#
```

Banner Grabbing

■ Active Banner Grabbing:

- ▶ Specially crafted packets are sent to remote OS and the responses are noted.
- ▶ The responses are then compared with a database to determine the OS.
- ▶ Response from different OSes varies due to differences in TCP/IP stack implementation.

Banner Grabbing

■ Passive Banner Grabbing:

- ▶ **Banner grabbing from error messages:** Error messages provide information such as **type of server**, **type of OS**, and **SSL tool** used by the target remote system.
 - ▶ **Sniffing the network traffic:** **Capturing** and **analyzing** packets from the target enables an attacker to determine OS used by the remote system.
 - ▶ **Banner grabbing from page extensions:** Looking for an **extension** in the URL may assist in determining the application version. Example: **.aspx** => **IIS** server and **Windows** platform.
-

Tools for Banner Grabbing

Telnet

- Default port 23.
- Can specify other ports:
 - telnet <IP> 80
- Generates banner if port open.

Netcat (nc)

- TCP/UDP networking utility.
- Syntax:
 - nc <IP> <port>
- Reads and writes raw data.
- Known as “Swiss Army Knife” tool.

Nmap

- sV switch for version detection.
- Automates banner grabbing.
- Performs OS fingerprinting

NetBIOS Enumeration

- **What is NetBIOS?**
- Network Basic Input/Output System.
- Developed for Windows networking.
- Provides:
 - Name service
 - Datagram service
 - Session service
- **NetBIOS Name Structure**
- 16-character ASCII name:
 - First 15 = hostname
 - 16th = service identifier

NetBIOS Enumeration

- **Why It's Valuable**
- Reveals:
 - Computer names
 - Workgroups
 - File sharing status
 - Master browser
 - MAC address

NetBIOS Enumeration Commands & Codes

Key Commands (nbtstat)

- `nbtstat -n` → Local name table
- `nbtstat -A <IP>` → Remote table by IP
- `nbtstat -a <hostname>` → By name
- `nbtstat -c` → Cache

Important NetBIOS Codes

- 00 → Workstation service
- 20 → File & Print sharing enabled
- 1D → Master browser
- 1E → Browser service elections

NetBIOS Enumeration Tools

- **Tools**
- SuperScan
- Hyena
- Winfingerprint
- NetBIOS Enumerator
- NSAuditor
- **Information Extracted**
- Shared folders
- Logged-in users
- Domain membership
- Service configuration
- Host OS details
- **Security Risk**
- Enables lateral movement.
- Helps attackers identify file servers.
- Useful for password attack targeting.

SNMP Enumeration Basics

- **What is SNMP?**
- Simple Network Management Protocol.
- Used to manage IP-enabled devices.
- Runs on UDP port 161.
- **Architecture**
- Manager
- Agents
- Management Information Base (MIB)
- **Key Concepts**
- OID (Object Identifier)
- MIB hierarchy
- Scalar objects (single value)
- Tabular objects (multiple entries)
- **Request Types**
- SNMP GET → Retrieve information
- SNMP SET → Modify configuration

SNMP Weaknesses

- **SNMP Weaknesses (Especially v1)**

- Default community strings:
 - Read-only → public
 - Read-write → private
- Sent in clear text (v1).
- Easily sniffed.
- Often left unchanged.

- **SNMPv3 Improvements**

- Encryption
- Authentication
- Message integrity

Comparison

Feature	Banner Grabbing	SNMP Enumeration	NetBIOS Enumeration
What It Is	Extracting service name & version from a server	Extracting device and infrastructure data using SNMP	Extracting Windows network information using NetBIOS
Main Purpose (Attacker)	Identify software version to find vulnerabilities	Map entire network infrastructure	Discover Windows systems, users, and shared resources
Main Purpose (Legitimate)	Check outdated services	Monitor routers, switches, servers	Enable Windows file sharing & name resolution
Protocol Type	Application layer services (HTTP, FTP, SSH)	Network management protocol	Windows network communication protocol
Common Ports	80 (HTTP), 443 (HTTPS), 21 (FTP), 22 (SSH)	UDP 161	UDP 137, 138 / TCP 139

Comparison

Type of Info Revealed	Service type & version	Hostname, interfaces, routing tables, ARP table, uptime	Computer name, domain/workgroup, logged-in users, shared folders
Information Sensitivity Level	Medium	High	Medium–High
Used Mostly On	Web servers, mail servers, FTP, SSH	Routers, switches, firewalls, printers	Windows machines in LAN
Biggest Risk	Targeted exploit selection	Full network blueprint exposure	Internal Windows network mapping
Example Data Revealed	Apache/2.4.49	VLAN IDs, internal IP ranges	\FINANCE-PC, HRShare folder
Common Tools Used	Nmap -sV, Telnet	snmpwalk, snmp-check	nbtstat, enum4linux
Modern Relevance	Very High	High (especially network devices)	Mostly legacy / internal networks
How To Secure Against It	Hide service versions, patch systems 	Use SNMP v3, restrict access, change community strings	Disable NetBIOS if not needed, block ports 137–139

LDAP Enumeration

- Port 389.
- Queries directory services.
- Retrieves:
 - Users
 - Groups
 - Organizational Units
 - Domain structure
- **Why LDAP Is Powerful**
- Designed to be queried.
- Can expose entire Active Directory structure.
- Often misconfigured.